

Sicherheit & technische Maßnahmen (TOM)

Kurzdokumentation der technischen Schutzmaßnahmen der Gedenkbuch-App (DSGVO Art. 32). Stand: 2026-08-02. Produktion: lebensgeschichten.ai.

1. Verschlüsselung

In Transit (Übertragung)

- Die App wird ausschließlich über HTTPS/TLS ausgeliefert (von Vercel erzwungen).
- Alle Backend-Aufrufe an Drittanbieter laufen über HTTPS:
- Microsoft Azure OpenAI (LLM, EU): `https://<resource>.services.ai.azure.com` (gpt-4.1, DataZone EU/westeurope)
- Microsoft Azure AI Speech (TTS/STT, EU): `https://<region>.tts.speech.microsoft.com` bzw. `https://<region>.api.cognitive.microsoft.com`
- Microsoft Azure Foundry – FLUX.2 [pro] (Bilderzeugung, EU): `https://<resource>.services.ai.azure.com`
- Supabase: TLS-gesicherte Verbindung
- **Keine US-Fallbacks mehr:** der Anthropic-LLM- und der OpenAI-Sprach-Fallback wurden am 2026-06-22 aus dem Code entfernt. Es gibt keinen Pfad zu `api.anthropic.com` / `api.openai.com` mehr; ist Azure nicht erreichbar, antwortet der jeweilige Endpunkt mit Fehler statt auf einen US-Anbieter auszuweichen.
- Keine unverschlüsselten (`http://`) Produktivverbindungen im Code.

At Rest (Speicherung)

- Supabase-Datenbank (Postgres) und Storage-Bucket `memorial-images` : serverseitig AES-256-verschlüsselt (Supabase-Standard).
- Vercel-Umgebungsvariablen (Secrets): verschlüsselt gespeichert.

2. Secret-Management

- Secrets liegen ausschließlich in Vercel-Umgebungsvariablen (Production), lokal in einer nicht versionierten `.env`.

- `.gitignore` schließt `.env` / `.env.*` aus; eine `.env` wurde nie committet (Git-History geprüft).

- **Das Frontend referenziert keine einzige Umgebungsvariable** — alle

Geheimnisse bleiben serverseitig in den `/api/*`-Functions. Der Browser spricht nur die eigene API an, nie direkt Azure/Supabase.

- Service-Role-Key: nur im Backend, umgeht RLS bewusst (siehe RLS unten).

- Pflicht-Secrets siehe `CLAUDE.md` → „Required environment variables“.

Rotation (organisatorisch): Bei Verdacht oder Personalwechsel die Keys beim jeweiligen Anbieter neu erzeugen und in Vercel (Production + Preview) ersetzen; `ADMIN_TOKEN_SECRET` -Wechsel invalidiert alle laufenden Admin-Sessions.

3. Zugriffs-/Audit-Logging

- Dauerhaftes Audit-Log in der Datenbank,

da Vercel-Logs auf dem Hobby-Plan flüchtig sind.

- Geschrieben über eine eigene Protokollfunktion (fail-open: ein Logging-Fehler bricht

nie die eigentliche Aktion ab). **PII-arm:** nur Akteur (uid), Aktion, Ziel-Code/-ID, IP, Zeitstempel — keine Inhalte, kein Passwort-Material.

- Protokollierte Aktionen:
- `login.success`, `login.failure`
- `memorial.create`, `memorial.delete`, `memorial.update`
- `contribution.delete`
- `user.create`, `user.update`, `user.delete`
- **Auswertung:** über das Supabase-Dashboard (Tabelle `audit_log`).
- **Aufbewahrung:** Einträge älter als 365 Tage werden vom täglichen

Cron-Lauf automatisch entfernt.

4. Zugriffskontrolle (Kurzüberblick)

- Admin-Endpunkte: HMAC-signierter Bearer-Token mit 12 h Ablauf, keine unsicheren Defaults.
- Mehrbenutzer-Isolation: Nicht-Admins sehen/bearbeiten nur eigene

Gedenkbücher.

- Öffentlicher Beitragenden-Flow: ein Beitrag nur per geheimer Beitrags-ID

(Capability); `/api/memorial` liefert nur eine Feld-Allowlist.

- Offene KI-Proxies an gültigen Code gebunden + Rate-Limiting, Login zusätzlich Brute-Force-gebremst.
- RLS auf allen Tabellen aktiviert, keine Policies → nur `service_role`

(Backend) greift zu.

5. Live-Sprachgespräch (Azure Voice Live) — ergänzt 2026-08-02

Der optionale vierte Mikrofon-Modus hält während des Interviews eine durchgehende Audioverbindung. Weil dabei Art.-9-Daten als Rohaudio fließen, gelten eigene Maßnahmen:

- **Kein Direktkontakt Browser ↔ Azure.** Ein WebSocket-Relay im eigenen Backend steht dazwischen. Grund:

Ein Browser-WebSocket kann keinen `Authorization`-Header setzen — Microsofts Beispiele hängen den Ressourcenschlüssel als Query-Parameter an, er läge damit im Browser. Über das Relay bleibt der Schlüssel serverseitig.

- **Region fest verdrahtet.** Die Sitzung geht ausschließlich an die Ressource in

Sweden Central. Der von Microsoft für Browser empfohlene WebRTC-Pfad (`/voice-live/realtime/calls`) wird bewusst **nicht** benutzt: Er nutzt laut Doku „global standard deployments“ und routet zur nächstgelegenen Region.

- **Modell-Allowlist.** Die

EU-Residenz hängt am Deployment-Typ des Chat-Modells, und den gibt Microsoft je Region und Modell vor. Ein nicht freigegebenes Modell (z. B. `gpt-realtime` , das nur als „Global standard“ existiert) **deaktiviert den Dienst**, statt ihn still global laufen zu lassen. Eine Fehlkonfiguration der Env-Variable kann die Rechtsgrundlage damit nicht unbemerkt aushebeln.

- **Nachrichten-Allowlist zum Dienst hin** (`CLIENT_ALLOWED_TYPES`). Der Browser darf

Audio und Antwortanforderungen schicken, aber **kein** `session.update` — Modell, Stimme, Sprache und Transkription setzt allein das Relay. Sonst könnte ein manipulierter Client die Sitzung auf ein teureres oder außereuropäisches Modell umbiegen.

- **Kurzlebiges Ticket statt Dauerzugang.** `POST /api/voicelive-token` prüft Buch-Code,

Budget und Sprache und stellt ein HMAC-signiertes Ticket mit 2 Minuten Gültigkeit aus (`ADMIN_TOKEN_SECRET`). Es dient nur dem Verbindungsaufbau.

- **Nie Standard, immer bewusste Wahl.** Der Modus steht seit dem 2026-08-02 allen

offen (der frühere Freischaltvorbehalt je Buch ist entfallen), ist aber **niemals voreingestellt**: Voreinstellung bleibt die Mischform (Mikrofon öffnet automatisch, die erzählende Person beendet per Knopfdruck). Der Live-Modus wird ausschließlich aktiv, wenn die Person ihn im Menü „Mikrofon-Modus“ selbst auswählt, und lässt sich jederzeit wieder verlassen. Jeder Fehler fällt still auf die Mikrofon-Modi zurück.

- **Im Begleiteten Modus abgeschaltet.** Sprechen zwei Menschen abwechselnd

(Begleitperson), bleibt der Live-Modus aus — eine durchgehende Verbindung mit Ausrichtung auf eine Stimme passt dort nicht.

- **Kein Audio-Mitschnitt.** Gespeichert wird ausschließlich das Transkript in derselben

Struktur wie im Mikrofon-Modus. Voice Live selbst speichert nach Microsoft-Doku nichts; die optionale Protokollierung für Support-Fälle ist nicht aktiviert.

- **Kostendeckel greift auch hier.** Jede Antwortrunde wird über `costRealtime` auf das

Buch gebucht; die Budget-Obergrenze stoppt die Sitzung wie jede andere KI-Funktion.